

Enforcing Security & Governance Guardrails using Enterprise Policy as Code

Agenda

- 01 Introduction
- 02 Azure Policy Overview & Use Cases
- 03 The Challenge with Azure Policy
- 04 Policy as Code
- 05 What is the Enterprise Policy as Code Solution
- 06 Demos

Introduction



Stephen Tulp

APAC Technology Strategist &
Distinguished Technologist

LinkedIn™



Microsoft®
Most Valuable
Professional

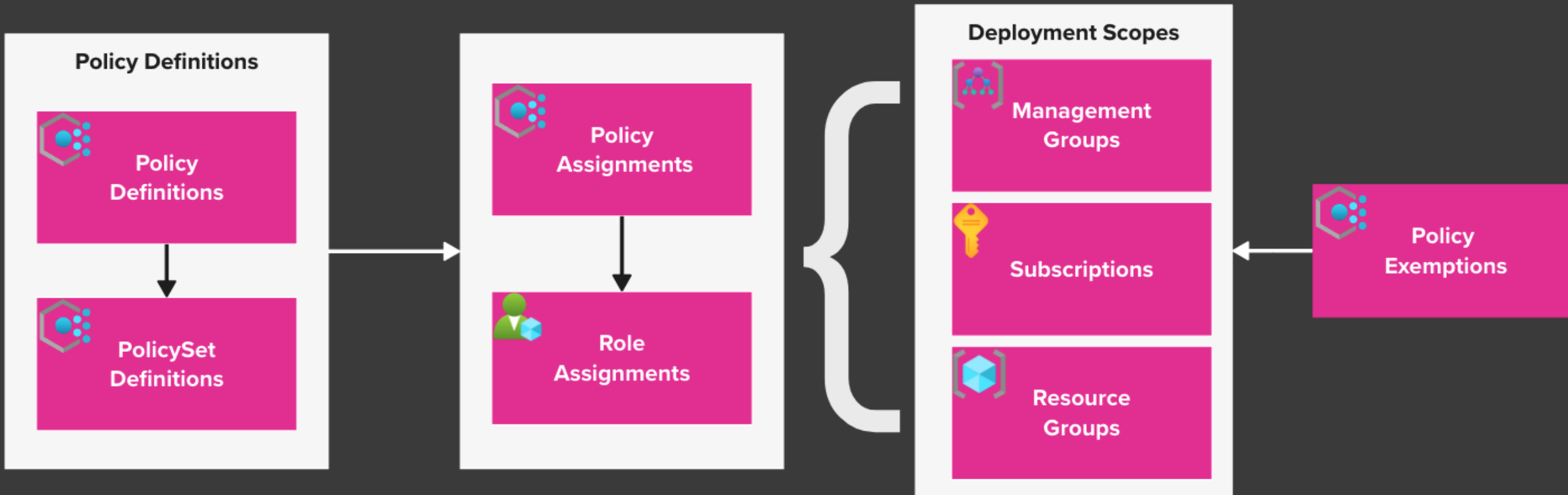
<https://blog.insight-services-apac.dev/>





“Azure Policy is the gatekeeper for security controls and guardrails for all Azure deployments. It is one of the most important security & governance capabilities in Azure.”

Azure Policy Components



Use Cases for Azure Policy

Tagging

- Mandatory tags
- Sub & RG inheritance

Monitoring

- Diagnostic settings
- NSG Flow logs
- Certification expiration

Data Protection

- Configure VM backup & ASR
- Storage/Disk/DB encryption

Network

- NSG Rules
- Gateways
- PaaS network rules
- Peering

Regulatory Compliance

- CIS
- NIST
- ASB
- ISO 27001

General

- Allowed locations
- Allowed SKUs
- Naming standards



Azure Policy Effects

Append

Evaluates before the request gets processed by a Resource Provider

AuditIfNotExist

Runs after a Resource Provider processed a create or update resource request

Deny

Deny prevents the request before being sent to the Resource Provider

DenyAction

Block requests based on intended action to resources at scale

DeployIfNotExist

Executes a template deployment when the condition is met. Requires Managed Identity

Disabled

Useful for testing situations or when the policy definition has parameterised the effect

Modify

Add, update, or remove properties or tags on a subscription or resource during creation or update



What are the Challenges with Azure Policy

- **Configuration Drift:** Policies may deviate from the intended configuration over time.
- **Lack of Documentation:** Insufficient documentation can lead to confusion about the existence and alignment of policies with governance and architectural specifications.
- **Security Incidents:** Policies that are removed and not reassigned can result in security breaches.
- **Operational Overhead:** Ignoring architectural specifications due to the removal of enforcing policies can increase operational workload.
- **Inconsistent Policy Development and Deployment:** An insecure and non-consistent approach introduces business operation risks.
- **Stakeholder Tension:** Conflicts can arise between operational and development stakeholders.

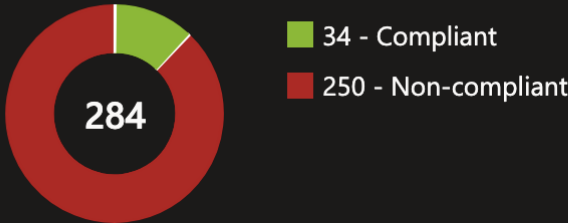


The Contrast between Governed and Ungoverned

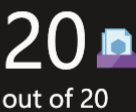
Overall resource compliance ⓘ



Resources by compliance state ⓘ



Non-compliant initiatives ⓘ



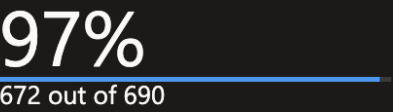
LEARN MORE

[Learn about Policy](#) ⓘ
[Onboarding tutorial](#)

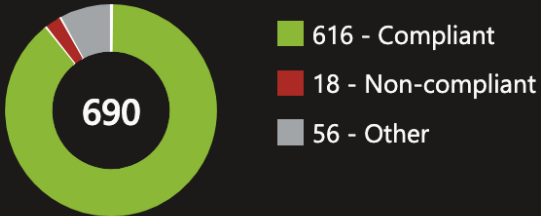
Non-compliant policies ⓘ



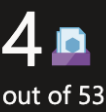
Overall resource compliance ⓘ



Resources by compliance state ⓘ



Non-compliant initiatives ⓘ



LEARN MORE

[Learn about Policy](#) ⓘ
[Onboarding tutorial](#)

Non-compliant policies ⓘ



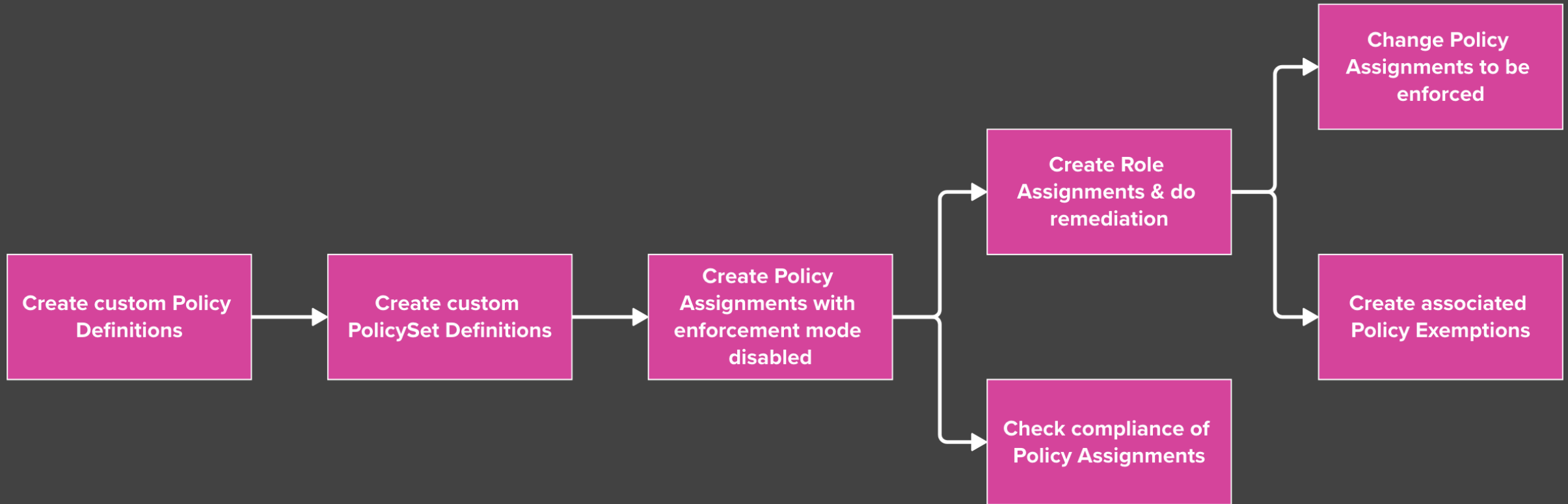
Policy as Code



Azure Policy as Code is the combination and union of Infrastructure as Code and DevOps. Keeping the Policy Definitions, Initiatives, Assignments, and Exemptions in source control means you will always have a single source of truth for these security & governance controls. Whenever a change is required, it should be tested and validated before being deployed into the environment.



Policy as Code Workflow



What is EPAC?



Enterprise Policy-as-Code (EPAC) is an open-source community project that provides a CI/CD automation solution for the development, deployment, management and reporting of Azure policy at scale. EPAC maintains a *Desired State* to provide a high level of assurance in highly controlled and sensitive environments, and a means of managing policy exemptions.



What is EPAC?

Manage Azure Policy at Scale

- Azure Policy Definitions, Azure Policy Set Definitions (Initiatives)
- Azure Policy Assignments
- Azure Policy Exemptions

Simple DevOps flow based on GitHub flow

- Feature branches
- Pull Requests
- Production approvals based on the defined plan
- Least privilege roles for assignments

Flexible Management Options

- Define the desired state
- Azure Policy Assignments without copy/paste
- Excel for effect settings instead of JSON
- Excel for managing Azure Policy Exemptions instead of JSON

Works Across Multiple Scenarios

- Any CI/CD tool Azure DevOps, GitHub, or other
- Single or multi-tenant environments, including Azure Lighthouse
- Greenfields or Brownfields environments
- EPAC PowerShell module & starter kit examples



Enterprise Policy as Code & GitHub Flow

Development in feature branch

- Develop against the EPAC dev environment
- Commit triggers CI build and deployment to *EPAC dev* environment
- CI build also calculates plan(s) for *EPAC prod* environments

PR changes into main branch

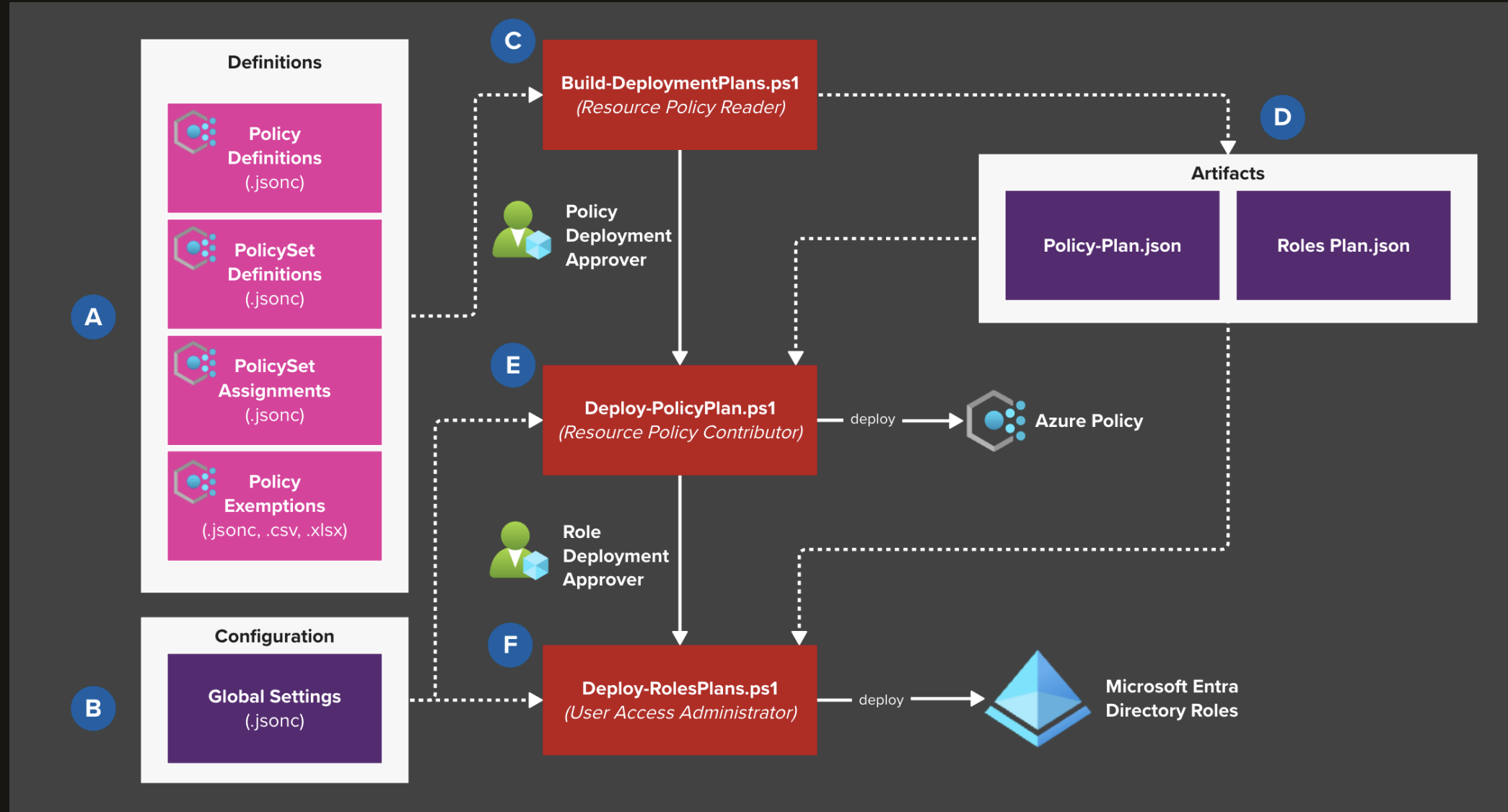
- Approvers **must** review the code **and** review *EPAC prod* environment plan(s)
- No extra build before merge (very expensive)

PR merge CD build (main branch)

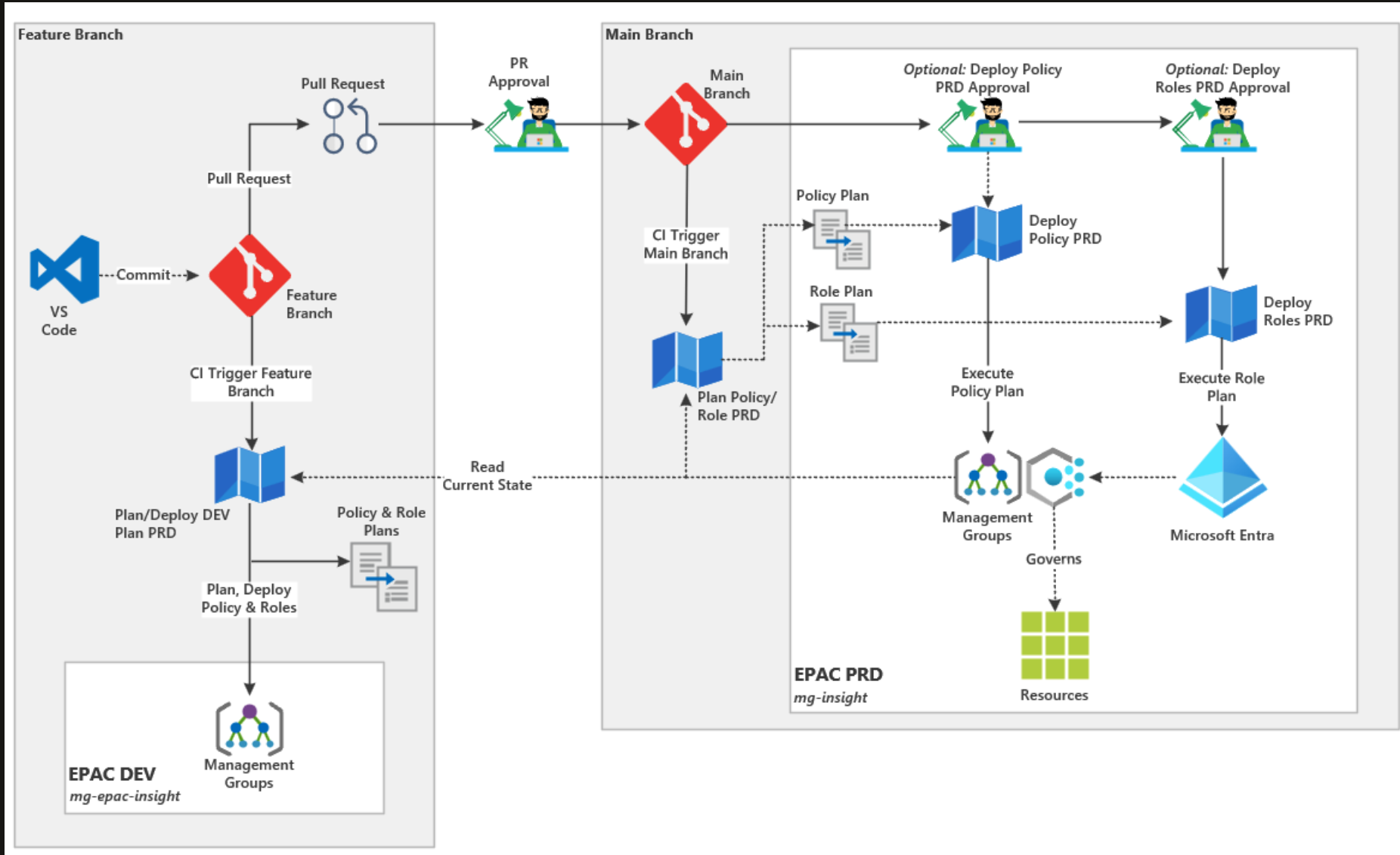
- CI build also calculates plans for *EPAC prod* environments
- Policy deployment stage approver(s) **must** review code changes **and** CD build plan(s)
- Role deployment stage approver(s) **must** review role assignment plan(s)



Deployment Process



EPAC Production Flow



EPAC Demo



Policy Assignments

Tenant Root Group



EPAC - Prod



Policy & Policy Set
Definitions



Platform



Landing
Zones

Decommissioned



Sandbox

Identity



Management



Connectivity



Corp

Online



Links and Takeaways

- Azure Policy Overview – <https://learn.microsoft.com/en-us/azure/governance/policy/overview>
- Enterprise Azure Policy as Code (EPAC) – <https://aka.ms/epac>
- AzAdvertiser – <https://www.azadvertizer.net/>
- Azure Governance Visualizer – [Azure Governance Visualizer \(AzGovViz\)](#)
- Awesome Azure Policy – <https://github.com/globalbao/awesome-azure-policy>

